By Sommer Compliance Book: Legal, Ethical, and Operational Governance for Autonomous Systems

By Sommer Compliance Book: Legal, Ethical, and Operational Governance for Autonomous Systems

Table of Contents

1. Introduction
2. Legal Foundations
    - 2.1 GDPR and Data Subject Rights
    - 2.2 EU AI Act and GPAI Compliance
    - 2.3 NIS2 Cybersecurity Requirements
3. Ethical Governance
    - 3.1 Responsible AI and HITL Oversight
    - 3.2 Bias Mitigation and Anti-Discrimination
    - 3.3 Transparency and Conduct
4. Intellectual Property and Digital Market Fairness
    - 4.1 IP Ownership and Licensing
    - 4.2 AI Training Prohibition
    - 4.3 Digital Commerce Compliance
5. Operational Compliance Protocols
    - 5.1 Contract Lifecycle Management
    - 5.2 Public LLM Usage Restrictions
    - 5.3 GDPR Rights Execution
6. Autonomous Agent Decision Logging Framework
    - 6.1 Purpose and Scope
    - 6.2 Logging Architecture
    - 6.3 Decision Categories and Metadata
    - 6.4 Auditability and Retention
7. Public-Facing Legal Integration
    - 7.1 Website Legal Hub
    - 7.2 Privacy Policy Requirements

- 7.3 Terms of Use Clauses

8. Continuous Improvement and Governance Review

---

1. Introduction

By Sommer operates at the intersection of experimental AI and European regulatory rigor. This Compliance Book codifies our legal, ethical, and operational commitments, ensuring that all AI engagements - including those involving autonomous agents - are transparent, auditable, and aligned with EU law.

2. Legal Foundations

2.1 GDPR and Data Subject Rights

- Legal basis for processing: consent, contract, legitimate interest.
- Rights: access, rectification, erasure, restriction, portability, objection.
- Contact: privacy@bysommer.net (By Sommer), compliance@imsor.com (Imsor.com).

2.2 EU AI Act and GPAI Compliance

- Risk-tiered classification: Minimal, Limited, High-Risk, GPAI.
- GPAI obligations: documentation, training data summaries, red-teaming, incident reporting.

2.3 NIS2 Cybersecurity Requirements

- Risk analysis, incident response, business continuity, MFA.
- Applies to essential/important entities in the EU.

3. Ethical Governance

3.1 Responsible AI and HITL Oversight

- HITL required for all high-stakes decisions.
- Clients bear final responsibility for output verification.

3.2 Bias Mitigation and Anti-Discrimination

- Dataset audits, mitigation protocols.
- Right to terminate contracts for unethical use.

3.3 Transparency and Conduct

- Code of Conduct prohibits unlawful/discriminatory behavior.

- Compliance monitoring embedded.

4. Intellectual Property and Digital Market Fairness

4.1 IP Ownership and Licensing

- Clients own final deliverables; By Sommer retains Provider IP.
- No warranty on copyrightability of AI-generated content.

4.2 AI Training Prohibition

- Website Terms prohibit use of content for AI training without consent.

4.3 Digital Commerce Compliance

- Explicit waiver of 14-day withdrawal right for digital goods.
- Auto-renewal and non-refundable terms clearly stated.

5. Operational Compliance Protocols

5.1 Contract Lifecycle Management

- MSA, AI & IP Addendum, and DPA required pre-engagement.

5.2 Public LLM Usage Restrictions

- No client data in public LLMs unless contractually authorized.

5.3 GDPR Rights Execution

- Deletion requests fulfilled within 30 days.
- Financial records retained per Danish law.

6. Autonomous Agent Decision Logging Framework

6.1 Purpose and Scope

To ensure accountability and auditability of autonomous agent behavior in production and research environments.

6.2 Logging Architecture

- Immutable, timestamped logs stored in secure, access-controlled environments.
- Logs include input prompts, model version, output, and decision rationale.

6.3 Decision Categories and Metadata

- Categories: Data Access, Content Generation, Escalation, Ethical Override, Consent Handling.
- Metadata: user ID (hashed), session ID, model confidence score, HITL override status.

6.4 Auditability and Retention

- Logs retained for 5 years.
- Accessible to compliance, legal, and DPO teams.
- Redaction protocols for sensitive data.

7. Public-Facing Legal Integration

7.1 Website Legal Hub

- Footer links to Privacy Policy, Cookie Policy, Terms of Use.
- Required checkboxes for affirmative consent on all forms.

7.2 Privacy Policy Requirements

- Enumerates GDPR rights.
- Contact emails for rights execution.

7.3 Terms of Use Clauses

- IP assertions.
- AI training prohibition.
- User conduct expectations.

8. Continuous Improvement and Governance Review

- Annual review of all policies.
- Stakeholder feedback loop.
- Alignment with evolving EU and global standards.

This Compliance Book is a living document. It reflects By Sommer's commitment to building trustworthy, transparent, and legally resilient AI systems - and to leading by example in the responsible development of autonomous technologies.